

Redes de Computadores II

Ciência da Computação

Robson Costa, Dr.
`robson.costa@ifsc.edu.br`

Instituto Federal de Santa Catarina
Campus Lages

Sumário

Unidade 1 – Segurança de redes de computadores

- 1.1 - Fundamentos de segurança
- 1.2 - Políticas de redes seguras
- 1.3 - Ataques
- 1.4 - Criptografia
- 1.5 - VPN (*Virtual Private Network*)
- 1.6 - *Firewall* e *Proxies*
- 1.7 - Ferramentas de monitoramento de redes de computadores

Fundamentos de segurança

A abrangência da segurança



Fundamentos de segurança

Segurança vs. Funcionalidade

- A segurança é **inversamente proporcional** as **funcionalidades** (serviços, aplicativos, aumento de complexidade das conexões, etc..);

Segurança vs. Produtividade

- A administração da segurança deve ser dimensionada, sem que a produtividade dos usuários seja afetada;
- Geralmente, a **segurança é antagônica à produtividade dos usuários**;

Fundamentos de segurança



Fundamentos de segurança - Confidencialidade

- Impedir que pessoas sem autorização possam acessar dados/informações;
- A informação transmitida somente pode ser acessível pelas partes autorizadas;



Fundamentos de segurança - Integridade

- Impedir que pessoas sem autorização possam realizar modificações em dados/informações;
- Entende-se como *modificações*:
 - Atualizar;
 - Atualizar status;
 - Apagar;
 - Criar;
 - Atrasar;
 - Responder mensagens;



Fundamentos de segurança - Disponibilidade

- Garantir que os dados/informações sejam entregues no momento em que estes sejam necessários;
- Os dados/informações estarão disponíveis para acesso no momento desejado;



Fundamentos de segurança - Autenticidade

- Validar a identidade de um usuário, ou dispositivo ou sistema;
- Garantir que as informações de identidade não sejam falsas;



Fundamentos de segurança - Não Repúdio

- Impedir que os usuários possam negar operações realizadas por eles;
- Em redes de computadores, garantir que nem o emissor e nem o receptor possam negar o envio/recepção das mensagens;



Políticas de redes seguras

O que é a Segurança da Informação?

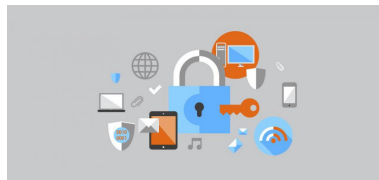
- Define restrições aos recursos da informação;
- A **segurança da informação** é a gestão de tais restrições;
- Para gerir tais restrições, precisam ser implementadas **Políticas de Segurança**;
 - Garante a continuidade do negócio;
 - Minimiza os riscos ao negócio;
 - Maximiza o retorno sobre os investimentos;



Políticas de redes seguras

Políticas de Segurança

- Conjunto de diretrizes e diretivas que definem formalmente as regras e os direitos dos funcionários e prestadores de serviços, visando a proteção adequada aos ativos da informação;
- Esta política está baseada em **diretrizes de segurança** e **diretivas de privacidade**;
 - Diretrizes → objetivos;
 - Diretivas → plano de ação;



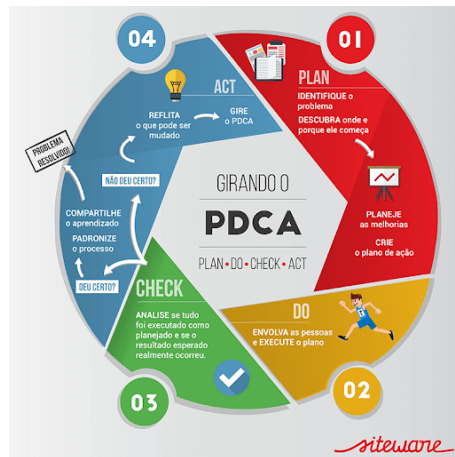
Políticas de redes seguras - Diretrizes de segurança

- Proteger as informações;
- Assegurar os recursos;
- Garantir a continuidade;
- Cumprir as normas estabelecidas;
- Atender às leis vigentes;
- Selecionar mecanismos para executá-las;
- Comunicar o seu descumprimento;

Políticas de redes seguras - Diretivas de privacidade

- As informações são coletadas de forma legal e sob o conhecimento do usuário;
- As informações são enviadas à empresa de forma segura com métodos de criptografia e certificação digital;
- As informações enviadas à empresa serão armazenadas de forma íntegra, sem alteração de qualquer parte;

Políticas de redes seguras - Ciclo de segurança da informação



Políticas de redes seguras - Confidencialidade e Privacidade

- A **confidencialidade** é uma propriedade das mensagens trocadas em uma rede de computadores a qual garante que somente pessoas autorizadas terão acesso ao seu conteúdo.
- A **privacidade (anonimato)** é uma propriedade dos nós comunicantes desta rede e que pode ser avaliada de dois pontos de vista diferentes:
 - dos elementos que se comunicam;
 - de um terceiro elemento que observa o tráfego de mensagens;
- A **privacidade (anonimato)** pode ser classificada como:
 - **Emissor** - não há possibilidade de se identificar o emissor original da mensagem;
 - **Receptor** - não há a possibilidade de se identificar o receptor final da mensagem;
 - **Mútuo** - não há a possibilidade de se identificar nem o emissor e nem o receptor da mensagem;

Ataques

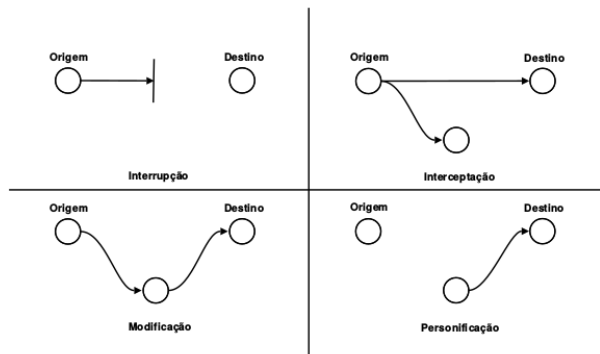
Segurança em Redes de Comunicação

- A segurança em redes de comunicação pode ser avaliada em termos de um canal seguro entre os pares comunicantes;
- Desta modo, um canal seguro protege os emissores e receptores de:
 - **Interceptações** - quando uma entidade não autorizada obtém acesso à informação, violando a propriedade de confidencialidade;
 - **Modificações** - quando uma entidade não autorizada modifica a informação enviada pelo emissor e a retransmite ao verdadeiro destinatário, violando a propriedade de integridade;
 - **Personificações** - quando uma entidade não autorizada transmite uma mensagem maliciosa se passando por uma entidade autêntica, violando a propriedade de autenticidade;

Ataques

Segurança em Redes de Comunicação

- Um canal seguro não necessariamente protege a comunicação de **interrupções**;
 - Quando o fluxo normal da mensagem é interrompido, impossibilitando que a informação chegue ao destino, violando assim a propriedade de disponibilidade;



Criptografia

Criptografia

- Qual a maneira mais segura de se manter um segredo?

Falha de segurança

Manter o algoritmo de cifragem e decifragem em segredo.

Chave criptográfica

Um algoritmo capaz de manter o segredo mesmo que todos conheçam a sua maneira de funcionamento.

Criptografia

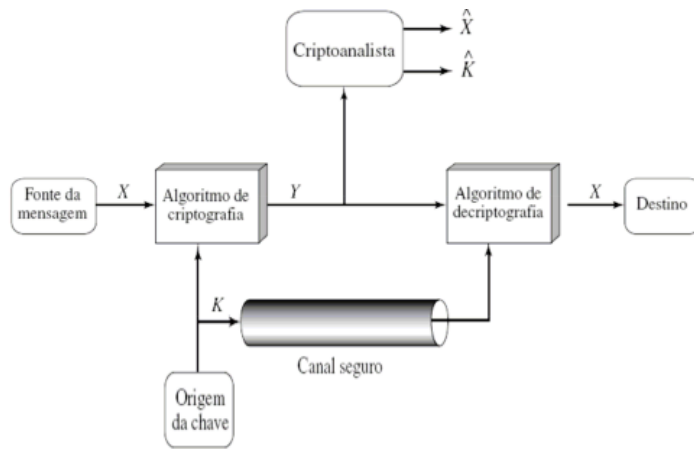
Criptografia

- Um algoritmo de criptografia bem projetado, **ao cifrar um mesmo texto com chaves diferentes deverá produzir um texto cifrado totalmente diferente;**
- Decifrar o texto cifrado com a chave errada deverá produzir um texto aleatório ininteligível;
- Se a chave utilizada for perdida, o texto cifrado, teoricamente, não pode ser recuperado pelo mesmo algoritmo de criptografia;

Criptografia - Criptografia simétrica

- Neste tipo de criptografia, a mesma chave deve ser utilizada tanto para se criptografar uma mensagem quanto para a sua decriptografia;
- Sendo assim, há a necessidade de que o emissor envie a chave de criptografia ao receptor através de um **canal seguro**, ou a combine previamente;
- Atualmente o **AES (*Advanced Encryption Standard*)** é o algoritmo de criptografia simétrica mais utilizado em sistemas computacionais;

Criptografia - Criptografia simétrica



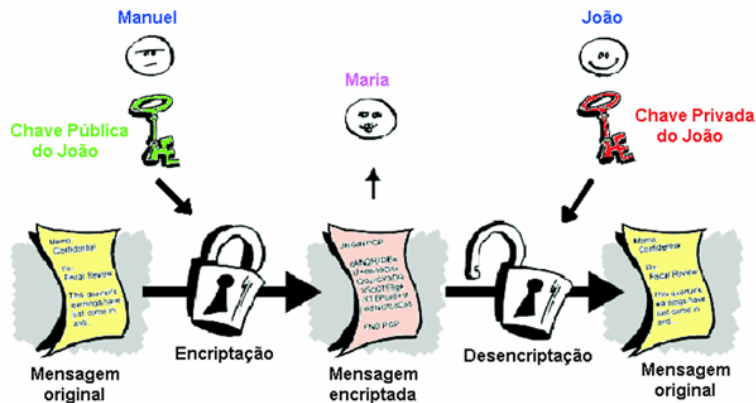
Criptografia - Criptografia assimétrica

- Na criptografia de chave simétrica a chave deve ser compartilhada entre os elementos comunicantes;
 - O grande problema é que um meio seguro deveria ser utilizado para a realização deste compartilhamento;
- Em 1976, um artigo publicado por *Whitfield Diffie* e *Martin Hellman* trouxe novas perspectivas para a criptografia;
 - Descrevia um método onde o estabelecimento de chaves não necessitava de um canal seguro previamente estabelecido;
- Este modo é conhecido atualmente como **criptografia de chave pública**;
- Nos anos seguintes diversos cripto-sistemas assimétricos foram propostos, como o RSA, Shamir e Adelman;

Criptografia - Criptografia assimétrica

- Na criptografia assimétrica a chave utilizada para criptografar é diferente da chave utilizada para decryptografar dados;
- Um par de chaves (pública e privada) é criado;
- **Chave Pública**
 - Utilizada exclusivamente para a criptografia dos dados;
 - Disponibilizada para todos que querem enviar dados criptografados ao criador desta chave;
- **Chave Privada**
 - Utilizada exclusivamente para a decryptografia dos dados;
 - Mantida em segredo pelo criador do par de chaves pública/privada;

Criptografia - Criptografia assimétrica



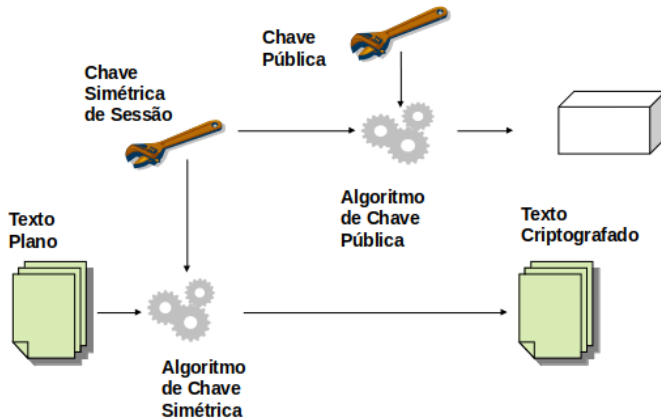
Criptografia - Criptografia assimétrica

- Desta forma, torna-se possível o compartilhamento de chaves (chave pública) sem comprometer a segurança do sistema criptográfico;
- Sendo assim, as chaves públicas são distribuídas entre as pessoas que desejam se comunicar, mantendo sigilo sobre as suas chaves privadas;
- Esta técnica possibilita também a realização de assinaturas digitais, sem que para isso seja necessária a presença de uma terceira fonte confiável;
- Para grandes quantidades de informações, algoritmos assimétricos são lentos (20Kb a 200Kb / seg.);
- Algoritmos simétricos são mais rápidos (+/- 30Mb / seg.);

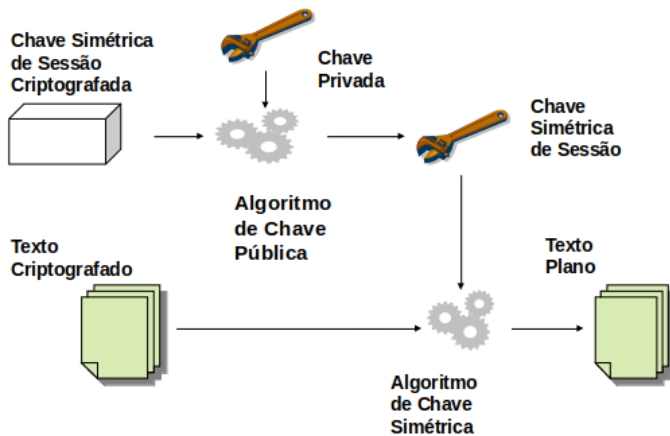
Criptografia - Envelopamento digital

- Como resolver o problema da **troca da chave simétrica**?
- Uma solução comumente aplicada é utilizar uma combinação (híbrida):
 - Cifrar uma chave simétrica com uma chave pública (assimétrica);
 - Realizar o envio seguro da chave simétrica;
 - Cifrar os dados propriamente ditos com criptografia simétrica;

Criptografia - Envelopamento digital



Criptografia - Envelopamento digital



Criptografia - Envelopamento digital

TLS (*Transport Layer Security*)

- Padrão global em tecnologia de segurança desenvolvido originalmente pela Netscape em 1994 com o nome de SSL (*Secure Socket Layer*);
- Após a Netscape vender a patente do SSL (na sua versão 3.0) para a IETF (*Internet Engineering Task Force*), este passou a ser chamado de TLS (*Transport Layer Security*);
- Cria um canal criptografado entre um servidor e um cliente sendo baseado na técnica de envelopamento digital;

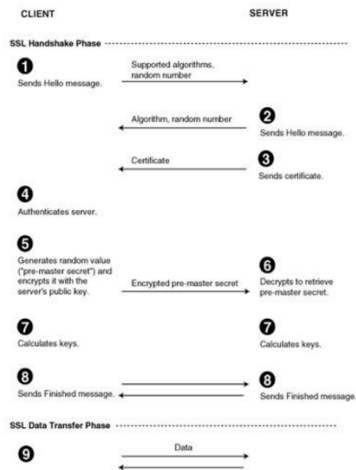
Criptografia - Envelopamento digital

TLS (*Transport Layer Security*)

- Opera como uma camada adicional entre a camada de aplicação e a camada de transporte;
- Torna-se assim independente do protocolo utilizado na camada de aplicação;
- Amplamente utilizado para garantir a segurança em comunicações baseadas no paradigma cliente/servidor como:
 - Serviços WEB (HTTPS);
 - Serviços de e-mail (SMTPS, IMAPS e POPS);
 - Serviços de transferência de arquivos (FTPS);

Criptografia - Envelopamento digital

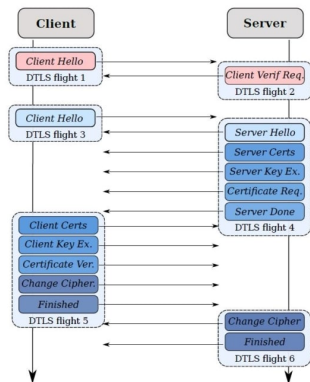
TLS (*Transport Layer Security*)



Criptografia - Envelopamento digital

DTLS (*Datagram Transport Layer Security*)

- Padrão global baseado no TLS para uso em datagramas UDP (RFC 9147);



Criptografia - Assinatura digital

- Criada a partir do uso de criptografia assimétrica;
- A autenticação de muitos documentos legais, é determinada pela presença de uma assinatura autorizada (não vale para fotocópias);
- Para que os **sistemas de mensagens computacionais** possam **substituir o transporte físico de documentos** em papel e tinta, deve-se encontrar um **método que permita assinar os documentos de um modo que não possa ser forjado**;

Problema:

Como criar um método substituto para as assinaturas escritas à mão?

Criptografia - Assinatura digital

- Necessita-se de um sistema através do qual uma parte possa enviar uma mensagem **assinada** para outra parte de forma que:
 - 1 O receptor possa verificar a identidade alegada pelo transmissor;
 - 2 O transmissor não possa repudiar o conteúdo da mensagem;
 - 3 O receptor não tenha a possibilidade de forjar ele mesmo a mensagem;
- Exemplificando com compra de ações:
 - 1 O cliente manda o agente comprar um lote de ações;
 - O agente precisa ter certeza de que o cliente realmente é quem ele diz ser;
 - 2 Após a compra, o valor das ações caem abruptamente;
 - O agente precisa garantir que o cliente não negue a operação;
 - 3 Após a compra, o valor das ações subam abruptamente;
 - O agente afirma que o cliente solicitou a compra de somente 1 ação, e guarda o restante do lote para ele;

Criptografia - Assinatura digital

- A criptografia assimétrica ajuda a resolver o **problema da distribuição de chaves simétricas** bem como os **problemas de autenticação e não repúdio**;
- Quando se usa o RSA, significa que qualquer texto simples que tenha sido cifrado com a chave pública somente pode ser decifrado utilizando-se a sua respectiva chave privada;

Pergunta:

O que aconteceria se o texto fosse cifrado com a chave privada?

Criptografia - Assinatura digital

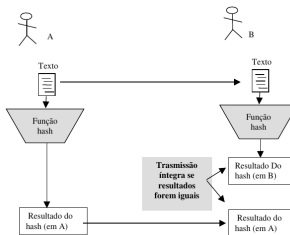
- Seguindo a mesma lógica, **ao cifrar um conjunto de dados com uma chave privada, somente a chave pública correspondente pode ser utilizada para decifrar o mesmo;**
- Desta forma, qualquer pessoa com a chave pública pode ler os dados, ou seja, não se pode manter confidencialidade;
- Qual o benefício?
 - Se os dados forem decifrados corretamente, somente podem ter sido cifrados pelo proprietário da chave privada correspondente;
 - Como somente o usuário original possui acesso à chave privada, somente ele pode ter criado e assinado esta mensagem;
- Qualquer documento **cifrado com uma chave privada é uma assinatura digital;**

Criptografia - Assinatura digital

- Uma assinatura é um fragmento de dados oriundos da mensagem e da chave pública;
- Trata-se de uma maneira de confirmar o conteúdo de uma mensagem e informar que é a pessoa quem diz ser (autenticidade);
- Permite verificar se os dados não foram alterados (integridade);
- Leis estão sendo criadas de forma a declararem uma assinatura digital como uma maneira de associar juridicamente a assinatura de documentos;

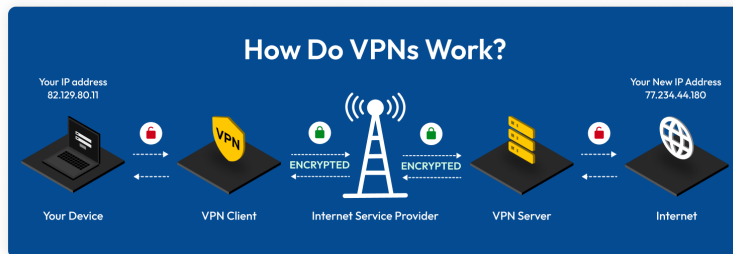
Criptografia - Assinatura digital

- Para garantir a integridade das informações uma **função hash** é utilizada na assinatura digital, transmissão de mensagens e transferência de dados;
- Alguns algoritmos: MD4, MD5 e SHA-1;
- Exemplo:
 - Usuário A envia para B o texto e o resultado da função *hash* aplicada sobre o texto;
 - B, ao receber o texto, aplica sobre este a função *hash* e compara o resultado obtido com o resultado enviado por A, se os resultados forem iguais o texto está íntegro, caso contrário o mesmo foi modificado;



VPN (Virtual Private Network)

- Serviço que cria uma rede virtual privada e segura (criptografada) entre um cliente e um servidor sobre uma rede pública (ex.: Internet);
- Este serviço também é conhecido como **tunelamento** entre o cliente e o servidor;



VPN (*Virtual Private Network*) - IPSec (*IP Security*)

- Segundo a RFC 6071, trata-se de um conjunto de protocolos com o objetivo de prover segurança a nível da camada de rede (L3) da pilha TCP/IP;
 - Lembrando que o TLS e o DTLS operam entre a camada de transporte (L4) e a camada de aplicação (L5);
- Isso torna o IPSec mais flexível, pois pode proteger tanto TCP quanto UDP;
- O IPSec é obrigatório no IPv6 e opcional no IPv4;
- Pode operar em dois modos diferentes:
 - **Transporte** - somente os dados (*payload*) do pacote IP é criptografado, mantendo o roteamento intacto;
 - **Tunelamento** - o pacote IP é criptografado por inteiro, necessitando-se assim encapsular o conteúdo cifrado em um novo pacote IP para distribuí-lo;

VPN (*Virtual Private Network*) - IPSec (*IP Security*)

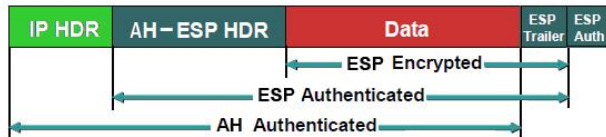
- Os principais protocolos do IPSec são:
 - **AH (*Authentication Header*)** - garante que os pacotes de dados sejam de uma fonte confiável e que os dados não tenham sido adulterados (função *hash*);
 - **ESP (*Encapsulating Security Payload*)** - criptografa o cabeçalho IP e o conteúdo (*payload*) para cada pacote; caso o modo de transporte seja usado, ele criptografa apenas o conteúdo; adiciona seu próprio cabeçalho e um trailer a cada pacote de dados;
 - **SA (*Security Association*)** - refere-se a vários protocolos usados para negociar chaves e algoritmos de criptografia; um dos protocolos SA mais comuns é o IKE (*Internet Key Exchange*);

VPN (Virtual Private Network) - IPSec (IP Security)

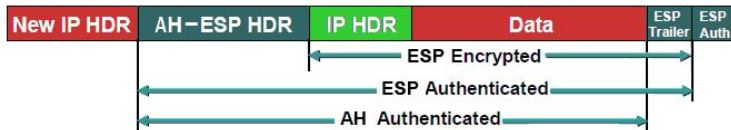
Original IP Packet



Transport Mode

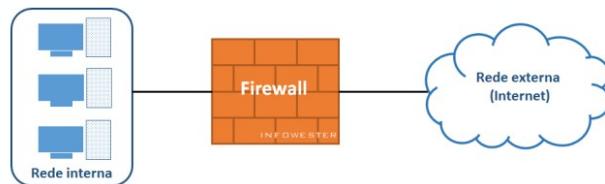


Tunnel Mode



Firewall e proxies - Firewall

- Trata-se de uma solução de segurança baseada em hardware ou software (mais comum);
- Um conjunto de regras ou instruções, analisa o tráfego de rede para determinar quais operações de transmissão ou recepção de dados podem ser executadas;



Firewall e proxies - Firewall

- O **filtro de pacotes** faz parte das primeiras soluções de firewall criadas na década de 1980;
- O firewall analisa as informações de cabeçalho dos pacotes (ex.: endereços IP, portas, tamanhos, tipos) e, de acordo com as regras estabelecidas define se este possui ou não autorização de transmissão;



Firewall e proxies - Firewall

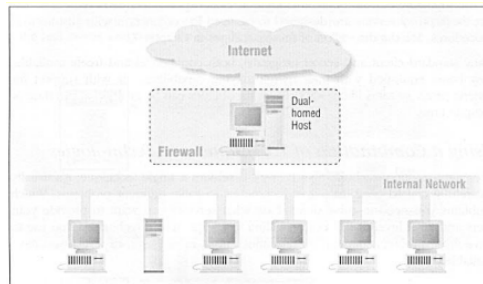
- Acaba limitando-se às camadas de rede e transporte;
- Esta filtragem pode ocorrer de forma **estática** ou **dinâmica**;
- **Estática**
 - A filtragem é realizada exclusivamente com base nas regras, independentemente da ligação que existe entre os pacotes;
- **Dinâmica**
 - Os filtros consideram o contexto da comunicação, criando novas regras temporárias para situações específicas;

Firewall e proxies - Firewall

- Conhecido como a evolução dos filtros dinâmicos, os filtros **stateful** operam realizando uma comparação entre o que está acontecendo e o que se espera acontecer;
- **Estática**
 - A filtragem é realizada exclusivamente com base nas regras, independentemente da ligação que existe entre os pacotes;
- **Dinâmica**
 - Os filtros consideram o contexto da comunicação, criando novas regras temporárias para situações específicas;

Firewall e proxies - Arquiteturas de Firewall

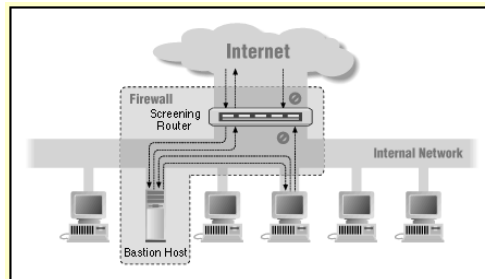
- **Dual-homed host**
 - Possui duas interfaces apenas, uma para a rede interna e outra para a rede externa, obrigando à todo o tráfego passar por estas interfaces, assim como em um proxy;



Firewall e proxies - Arquiteturas de Firewall

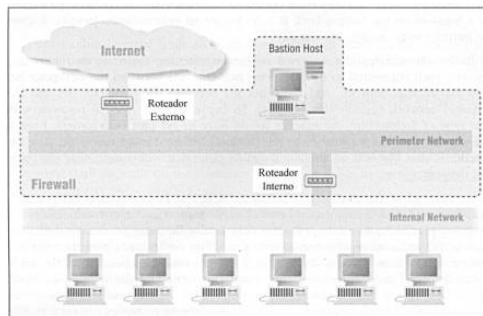
- **Screened host**

- Duas máquinas fazem a filtragem, uma como roteador (*screening router*) e outra chamada de *bastion host*;



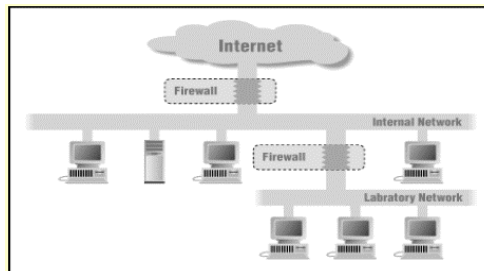
Firewall e proxies - Arquiteturas de Firewall

- **Screened subnet**
 - Nesta arquitetura o bastion host fica em uma DMZ (*Demilitarized Zone*);



Firewall e proxies - Arquiteturas de Firewall

- **Internal firewall**
 - Visa garantir a segurança entre os segmentos de uma rede;



Firewall e proxies - Arquiteturas de Firewall

- Melhor desempenho em grandes volumes de tráfego por utilizarem o sistema em *firmware*;



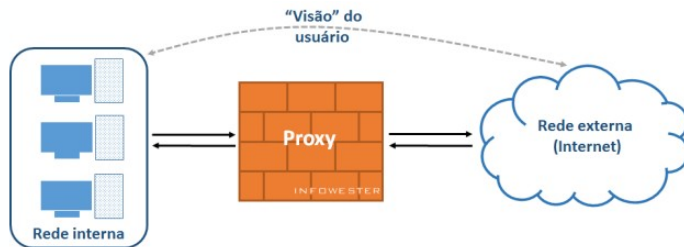
Firewall e proxies - Arquiteturas de Firewall

Limitações

- Pode comprometer o desempenho de uma rede;
- Revisão periódica das políticas de segurança;
- Novos serviços podem não ser contemplados em regras já implementadas;
- Dependendo da arquitetura implementada, o firewall não impede as atividades maliciosas geradas a partir da rede interna;
- O firewall não consegue interceptar uma conexão que não passe por ele (ex.: conexão 3G);

Firewall e proxies - Proxies

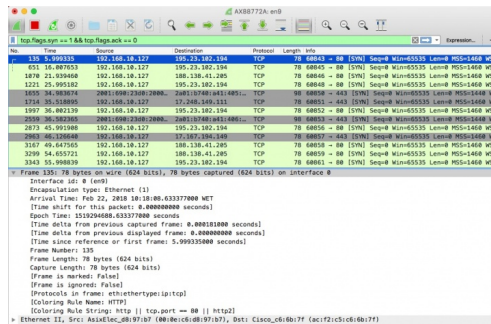
- Conhecido também como firewall de aplicação ou proxy de serviços;
- Atuam filtrando informações da camada de aplicação (L5);



Ferramentas de monitoramento de redes de computadores

Sniffer de rede

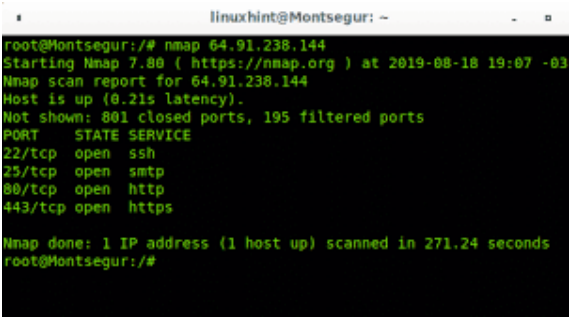
- Ferramenta capaz de capturar e analisar o tráfego de rede;
 - Wireshark;
 - Network Miner;
 - Capsa Packet Sniffer;



Ferramentas de monitoramento de redes de computadores

Descoberta de Rede e Autoria de Segurança

- Ferramenta capaz de realizar a descoberta de máquinas conectadas em uma rede específica e obter informações de um computador remoto;
 - Nmap;

A terminal window titled 'linuxhint@Montsegur: ~' displays the output of an Nmap scan. The user enters 'nmap 64.91.238.144'. The output shows the scan is starting at 2019-08-18 19:07, reports the host is up, and lists open ports: 22/tcp (ssh), 25/tcp (smtp), 80/tcp (http), and 443/tcp (https). The scan took 271.24 seconds.

```
linuxhint@Montsegur: ~
root@Montsegur:/# nmap 64.91.238.144
Starting Nmap 7.80 ( https://nmap.org ) at 2019-08-18 19:07 -03
Nmap scan report for 64.91.238.144
Host is up (0.21s latency).
Not shown: 801 closed ports, 195 filtered ports
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 271.24 seconds
root@Montsegur:/#
```